Horizon Scan NFR — Validazione: una riga per rischio (nel radar o in osservazione), KRI, azione e notizia · Ciclo 2026Q3 · dati al 30/09/2026 · da validare · Uso interno

VALIDATORE — dopo ogni ciclo trimestrale (obbligatorio: il ciclo dopo non parte finche' non e' validato) e, se si vuole, dopo ogni settimana per le notizie. Qui ci sono solo i periodi ancora da validare (riga 3). Per cambiare valori di un ciclo GIA' VALIDATO: python esegui_ciclo_locale.py riapri (D-76), poi qui come sempre e valida, quante volte serve; in riapertura il grigio e' il valore validato, non c'e' il limite di un punto e Respingi = Sì toglie un KRI o annulla un'azione.

Come si valida: una riga per rischio (nel radar o in osservazione), KRI, azione e notizia. Le celle GIALLE contengono gia' i valori proposti dagli agenti (accanto, in grigio, la proposta): se sei d'accordo non toccarle, la riga vale come accettata. Se non sei d'accordo scrivi il valore giusto nella cella gialla (anche piu' di uno nella stessa riga) e il perche' in Motivazione, almeno 10 caratteri: la cella cambiata diventa arancio, la Motivazione resta rossa finche' manca. Per togliere un KRI, un'azione o una notizia: Respingi = Sì, con la motivazione (un rischio non si respinge: si rettifica, o si toglie con il comando dismetti). Segnalazioni dei controlli (ultima colonna dei rischi): cio' che lo script e A5 (se usato) hanno trovato su quel rischio, anche sui suoi KRI e azioni; ⚑ davanti al nome = almeno una segnalazione DA MOTIVARE: la Motivazione e' obbligatoria anche se non cambi nulla. Score composito e Margine di Mosca si ricalcolano mentre scrivi, con i valori gialli e le azioni non respinte: rosso AGIRE ORA, giallo entro l'anno, verde con margine; tra parentesi il valore con le sole proposte, se diverso.

Poi salvare e CHIUDERE il file e lanciare python esegui_ciclo_locale.py valida --periodo <ciclo o lunedi'> --validatore "<funzione>". Il comando controlla tutte le righe prima di applicarne una (se una non va, non applica niente e le elenca con il numero di riga); poi le righe del periodo escono da questo foglio e il dettaglio campo per campo (proposta, valore deciso, motivazione, chi e quando) resta nel foglio Storico_Validazioni. Le colonne grigie si leggono soltanto; non inserire ne' cancellare righe (se succede: python esegui_ciclo_locale.py griglia ricostruisce il foglio e conserva cio' che hai gia' scritto).

Criteri — Rischio: il punteggio corrisponde al descrittore della rubrica, dati razionale e fonti (foglio Metodologia); un valore cambiato e' intero 1-5, al massimo un punto dal ciclo precedente (non in riapertura), motivato con un'evidenza (la Velocity puo' restare vuota = non valutata, o entrare con qualunque valore); anni di adeguamento da 0 a 30 o vuoti. KRI: respingere se la fonte dati non e' identificabile o se non misura il rischio; cambiare le soglie (entrambe; allerta >= attenzione, crescente = peggio; vuote = da definire) o un valore rilevato errato. Azione: respingere se duplicata o non pertinente al rischio; cambiare Owner (una funzione: il nome di una persona non si accetta) o Orizzonte (3, 6 o 12 mesi). Notizia: cambiare Rischio o Segnale; respingere se non pertinente o gia' contata. Stato del rischio (D-79): la colonna Stato dice dove lo mette la regola e perche'; Decisione sullo stato = Automatico (vale la regola), Radar (resta o entra nel radar) o Osservazione (resta fuori), con la Motivazione; lo stato si ricalcola con valida.

Prima di decidere leggere i rilievi di A5 e dei controlli (colonna Rilievi del RiskRegister; rilievi del ciclo in Sintesi_Cicli; file Esito_controlli del ciclo). La proposta dell'agente non si cancella mai: le rettifiche motivate servono a migliorare gli agenti.

Da validare: ciclo 2026Q3 (53 righe) — poi, con il file chiuso: python esegui_ciclo_locale.py valida --periodo <ciclo o lunedi'> --validatore "<chi valida>"

RISCHI — ciclo 2026Q3 (13 righe): i quattro punteggi, gli anni di adeguamento e la decisione sullo stato (Automatico, Radar, Osservazione: D-79)

ID	Rischio	Imp. proposto	Imp.	Prob. proposto	Prob.	Pross. proposto	Pross.	Vel. proposto	Vel.	Anni adeg. proposto	Anni adeg.	Motivazione (se cambi un valore)	Score composito (calcolato)	Margine di Mosca Z−(X+Y), anni (calcolato)
NFR-01	Frodi su pagamenti istantanei abilitate da AI generativa	4	4	4	4	4	4	5	5	—			4,20	AGIRE ORA · -0,25
NFR-02	Concentrazione su un fornitore cloud critico	4	4	2	2	3	3	4	4	—			3,30	Entro l'anno · 0,25
NFR-03	Greenwashing nella commercializzazione di prodotti ESG	3	3	3	3	4	4	2	2	—			3,00	Entro l'anno · 0,00
NFR-04	Eventi climatici estremi su sedi e data center	3	3	3	3	3	3	2	2	—			2,80	Entro l'anno · 0,75
NFR-05	Errori di processo nella migrazione del core banking	3	3	3	3	3	3	3	3	—			3,00	Margine · 1,00
NFR-06	Esfiltrazione di dati tramite strumenti di AI non autorizzati	3	3	3	3	3	3	3	3	—	1	Estendere il DLP e rivedere i profili di accesso ai servizi di AI richiede circa un anno di lavori.	3,00	Entro l'anno · 0,25 (era 0,75)
NFR-07	Ransomware presso un fornitore di servizi di pagamento	4	4	3	3	3	3	5	5	—			3,75	Entro l'anno · 0,75
NFR-08	Accessi impropri di dipendenti ai dati dei clienti	3	3	2	2	3	3	3	3	—			2,75	Entro l'anno · 0,25 (era 1,00)
NFR-09	Violazione di sanzioni internazionali tramite triangolazioni	4	4	2	2	2	2	3	3	—			2,90	Margine · 1,25
NFR-10	Informazioni errate ai clienti da assistenti di AI generativa	3	3	3	3	3	3	n.v.	3	—		Il registro reclami del trimestre mostra che le risposte errate dell'assistente arrivano ai clienti in giorni: velocity 3.	3,00	Margine · 1,00
NFR-11	Fine del supporto dei sistemi di pagamento legacy	3	3	3	3	3	3	2	2	3	3		2,80	AGIRE ORA · -1,75
NFR-12	Errori operativi nei pagamenti istantanei obbligatori	3	3	4	4	4	4	4	4	—			3,65	Entro l'anno · 0,00
NFR-16	Vertenze e carenza di tecnici nei ruoli IT critici	3	3	2	2	1	1	n.v.		—			2,19	Margine · 2,25

KRI — ciclo 2026Q3 (25 righe): valore rilevato e soglie; Respingi = Sì toglie il KRI

KRI	Indicatore	Tipo	Valore proposto	Valore	Soglia att. proposto	Soglia att.	Soglia all. proposto	Soglia all.	Respingi	Motivazione (se cambi un valore o respingi)
NFR-01-K1	Tentativi di frode APP per 10.000 bonifici istantanei	Evoluzione	5,1	5,3	3	3	6	6		Dato definitivo del report antifrode di ottobre: 5,3 (il 5,1 era la stima provvisoria).
NFR-01-K3	Tempo medio di blocco di un beneficiario fraudolento	Esposizione	3	3	4	4	12	12		
NFR-02-K1	Quota di servizi critici sul fornitore cloud principale	Esposizione	72	72	60	60	75	75		

NFR-02-K2	Incidenti dei fornitori cloud critici con impatto sui servizi nel trimestre	Evoluzione	0	0	2	2	4	4		
NFR-03-K1	Reclami su prodotti ESG ogni 1.000 contratti	Evoluzione	1,9	1,9	1,5	1,5	3	3		
NFR-03-K2	Quota di prodotti ESG senza revisione dei claim nell'anno	Esposizione	—		20	20	40	40		
NFR-04-K1	Sedi critiche in aree a rischio idrogeologico senza piano specifico	Esposizione	2	2	1	1	3	3		
NFR-04-K2	Giorni di indisponibilita' di sedi per eventi climatici	Evoluzione	0	0	2	2	5	5		
NFR-05-K2	Incidenti di produzione legati alla migrazione	Evoluzione	4	4	3	3	6	6		
NFR-05-K3	Quota di controlli di processo non ridisegnati sul nuovo core	Esposizione	18	18	30	30	60	60		
NFR-06-K1	Tentativi di caricamento di dati riservati su servizi AI non autorizzati	Evoluzione	6	6	10	10	30	30		
NFR-06-K2	Quota di dipendenti senza formazione sull'uso dell'AI	Esposizione	22	22	20	20	40	40		
NFR-07-K1	Fornitori di pagamento critici senza test di ripristino da ransomware	Esposizione	1	1	1	1	2	2		
NFR-07-K2	Ore di indisponibilita' del gateway di pagamento nel trimestre	Evoluzione	2,5	2,5	4	4	12	12		
NFR-08-K1	Accessi ai dati clienti senza pratica associata	Evoluzione	22	22	20	20	50	50		
NFR-08-K2	Utenze con profili di accesso non rivisti nell'anno	Esposizione	5	5	5	5	15	15		
NFR-09-K1	Pagamenti bloccati dal filtro sanzioni ogni 10.000 verso paesi di transito	Evoluzione	4,2	4,2	2	2	5	5		
NFR-09-K2	Clienti corporate ad alto rischio senza due diligence rafforzata aggiornata	Esposizione	9	9	5	5	15	15		
NFR-10-K1	Risposte del chatbot contestate ogni 1.000 conversazioni	Evoluzione	1,9	1,9	—	2	—	5		Soglie fissate dalla funzione di rischio sulla base dello storico reclami del 2025.
NFR-10-K3	Quota di risposte del chatbot non campionate dal controllo qualita'	Esposizione	45	45	20	20	50	50		
NFR-11-K1	Componenti del sistema di pagamento fuori supporto	Esposizione	6	6	3	3	8	8		
NFR-11-K2	Vulnerabilita' senza patch disponibile sui sistemi legacy	Evoluzione	5	5	2	2	6	6		
NFR-12-K1	Differenze di riconciliazione sui bonifici istantanei aperte oltre 1 giorno	Evoluzione	12	12	10	10	30	30		
NFR-12-K3	Tempo medio di risoluzione delle eccezioni sui pagamenti istantanei	Esposizione	4,5	4,5	4	4	12	12		
NFR-02-K3	Interruzioni di servizi critici presso il fornitore cloud principale nel trimestre	Evoluzione	—		1	1	3	3		

AZIONI — ciclo 2026Q3 (15 righe): owner e orizzonte; Respingi = Sì non approva l'azione

Azione	Descrizione	Owner proposto	Owner (una funzione)	Orizzonte proposto	Orizzonte	Respingi		Motivazione (se cambi un valore o respingi)
2026Q3-NFR-01-A1	Attivare la verifica fuori banda per bonifici istantanei sopra soglia verso beneficiari nuovi. Responsabile la Funzione Antifrode, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Antifrode	Funzione Antifrode	3 mesi	3 mesi			
2026Q3-NFR-01-A2	Campagna di sensibilizzazione dei clienti corporate sulle frodi con voce clonata. Responsabile la Direzione Marketing e Comunicazione, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Direzione Marketing e Comunicazione	Direzione Marketing e Comunicazione	6 mesi	6 mesi			
2026Q3-NFR-02-A1	Chiudere i rilievi minori emersi dal test di exit strategy entro il prossimo trimestre. Responsabile la Funzione ICT & Security Risk, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione ICT & Security Risk	Funzione ICT & Security Risk	3 mesi	3 mesi			

2026Q3-NFR-02-A2	Valutare lo spostamento di un servizio critico sulla nuova region nazionale del fornitore. Responsabile la Direzione Sistemi Informativi, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Direzione Sistemi Informativi	**Direzione Sistemi Informativi**	12 mesi	**12 mesi**			
2026Q3-NFR-03-A1	Completare la revisione indipendente dei claim ambientali di tutti i prodotti ESG in catalogo. Responsabile la Funzione Compliance, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Compliance	**Funzione Compliance**	3 mesi	**3 mesi**			
2026Q3-NFR-04-A1	Provare i piani di continuita' delle due sedi critiche con un'esercitazione di ripartenza in sede alternativa. Responsabile la Funzione Business Continuity, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Business Continuity	**Funzione Business Continuity**	6 mesi	**6 mesi**			
2026Q3-NFR-05-A1	Monitoraggio giornaliero degli incidenti post-migrazione con escalation entro 4 ore. Responsabile la Funzione Operations, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Operations	**Funzione Operations**	3 mesi	**3 mesi**			
2026Q3-NFR-06-A1	Completare la formazione obbligatoria sull'uso dell'AI per tutto il personale. Responsabile la Direzione Risorse Umane, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Direzione Risorse Umane	**Direzione Risorse Umane**	6 mesi	**6 mesi**			
2026Q3-NFR-06-A2	Chiedere all'audit interno la verifica dell'estensione del DLP. Responsabile la Funzione Sicurezza delle Informazioni, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Sicurezza delle Informazioni	**Funzione Sicurezza delle Informazioni**	6 mesi	**6 mesi**			
2026Q3-NFR-07-A1	Inserire nel contratto con il fornitore del gateway di pagamento tempi di ripristino garantiti dopo un attacco ransomware, con penali. Responsabile la Funzione ICT & Security Risk, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione ICT & Security Risk	**Funzione ICT & Security Risk**	6 mesi	**6 mesi**			
2026Q3-NFR-08-A1	Bloccare in automatico gli accessi ripetuti ai dati clienti senza pratica associata, con avviso al responsabile. Responsabile la Funzione Sicurezza delle Informazioni, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Sicurezza delle Informazioni	**Funzione Sicurezza delle Informazioni**	3 mesi	**3 mesi**	**Sì**		Gia' prevista dal piano IAM approvato a luglio: azione duplicata.
2026Q3-NFR-09-A1	Formare gli operatori dei pagamenti esteri sugli indicatori di triangolazione segnalati dalle autorita'. Responsabile la Funzione Compliance, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Compliance	**Funzione Compliance**	12 mesi	**12 mesi**			
2026Q3-NFR-10-A1	Definire i temi su cui il chatbot non risponde e passa la conversazione a un operatore (reclami, condizioni contrattuali, tassi). Responsabile la Funzione Customer Experience, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Customer Experience	**Funzione Customer Experience**	3 mesi	**3 mesi**			
2026Q3-NFR-11-A1	Isolare in un segmento di rete dedicato le componenti fuori supporto del sistema di pagamento, in attesa della sostituzione. Responsabile la Funzione IT Operations, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione IT Operations	**Funzione IT Operations**	12 mesi	**12 mesi**			
2026Q3-NFR-12-A1	Avvisare in automatico il responsabile delle operazioni di ogni differenza di riconciliazione sui bonifici istantanei aperta a fine giornata. Responsabile la Funzione Operations, con avvio nel trimestre e un esito verificabile da riportare al comitato rischi alla scadenza.	Funzione Operations	**Funzione Operations**	3 mesi	**3 mesi**			

NOTIZIE — nessuna riga da validare

Notizia	Titolo	Rischio proposto	Rischio	Segnale proposto	Segnale	Respingi	Settimana		Motivazione (se cambi un valore o respingi)

Lo stato di ogni riga (da decidere, applicata), chi ha validato e quando e, per ogni valore, la proposta e il valore deciso li registra il comando valida nel foglio dati Storico_Validazioni: non si scrive a mano.